MOTOSECURE | A NEXUS TECH LABS PRODUCT

Security Assessment Report

Engineering and security review of the MotoSecure platform: findings, evidence and remaining risks

Document ID	MS-ASR-001
Version	1.0 (draft for review)
Date	2 November 2026
Status	Draft for institutional review
Classification	Confidential
Publisher	NEXUS Tech Labs
Baseline	MotoSecure source archive as reviewed on 2 November 2026 (backend, web, mobile)
Related documents	MS-ARCH-001 Architecture; MS-SRS-001 Requirements; MS-SEC-001 Governance Policy
Approval	[Name, title and date - to be completed by the document owner]

This document describes the software as implemented in the reviewed source archive. Statements about hosting and deployment reflect the owner's reported configuration and were not independently verified. It is not a security certification, penetration-test report or compliance assessment. The reviewer also developed much of the code under review, so this is a self-assessment and does not replace an independent assessment.

Contents

1. Executive summary 3
2. Scope and method 3
2.1 What was reviewed 3
2.2 Activities 4
2.3 Severity scale 4
2.4 Verification states 4
3. Test and check results 4
3.1 Executed 4
3.2 Unit suite contents 5
3.3 Written but not executed 5
3.4 Static scan triage 6
4. Findings summary 6
5. Detailed findings 7
6. Remaining risks and recommendations 17
6.1 Before a pilot 17
6.2 Within the first months of a pilot 17
6.3 Longer term 17
7. Reproducing and extending this assessment 17
Appendix A. Static scan rule catalogue and baseline counts 17

1. Executive summary

MotoSecure was reviewed on 2 November 2026 ahead of an institutional review and potential pilot. The review inspected the backend, web and mobile source, mapped its 31 API routes and five roles, strengthened the code where weaknesses were confirmed, and wrote automated tests for authorization and tenant isolation.

Measure	Result
Findings	24 in total: 5 high, 16 medium, 2 low, 1 informational
Remediated in code	16 findings (14 fully, others reviewed-only or needing an operational step)
Open	8 findings (recommendations, operational actions or decisions)
Static scan (before / after)	17 high, 17 medium, 3 low -> 0 high, 0 medium, 3 low
Unit tests executed	51 of 51 passed
Integration tests	122 written; NOT executed (the review environment could not install the required packages)
Dependency advisory scan	NOT run (no network access)
Penetration test, security certification, compliance assessment	NOT performed

What the high findings were

Live demonstration credentials were published on the login page; the badge verification endpoint wrote to the database and exposed full rider details to anyone; several create and edit routes accepted any field from the client; and cross-municipality references were not validated. All four are fixed in the code. A fifth, a secrets file that travelled with project archives, needs credential rotation that only the owner can perform.

What this report does not establish

It does **not** show that the system is free of vulnerabilities, that the HTTP-level authorization tests pass (they have not yet been run), that dependencies are free of known advisories, or that the deployed service matches the reviewed source. Before a pilot, run the test and audit steps in section 7 and commission an independent penetration test.

2. Scope and method

2.1 What was reviewed

The source archive as last delivered to the owner (backend, web, mobile, scripts), including the Express API, Mongoose models, React web app and Expo mobile app. The deployed services and their configuration were not accessed. The owner reports that the mobile app was upgraded locally to Expo SDK 57; the archive's mobile manifest still pins SDK 51, so mobile dependency versions in this review are those of the archive.

2.2 Activities

Activity	Performed	Notes
Manual code review of authentication, authorization, data access, configuration and client storage	Yes	All backend routes, middleware and models; web and mobile authentication, offline and verification flows
Static analysis	Yes (limited)	A project-specific pattern scanner (scripts/static-checks.js), not a commercial SAST product; plus JavaScript and JSX syntax checking of every source file with the TypeScript parser
Secrets scan	Yes (limited)	Pattern-based within the scanner and a check for a local secrets file
Unit tests	Yes	Executed; results in section 3
HTTP-level integration tests	Written only	Need express, mongoose, supertest and a MongoDB engine; the environment had no network
Dependency vulnerability scan	No	Requires access to the npm advisory database
Dynamic testing or penetration test of the deployed system	No	Not authorised and not attempted; no production system was touched
Infrastructure and cloud configuration review	No	Settings live in provider dashboards
Mobile binary analysis, device testing, load testing	No	

2.3 Severity scale

Severities are the reviewer's qualitative judgement of likelihood and impact for a municipal pilot holding personal data of drivers; they are not CVSS scores. **High**: likely to lead to unauthorised access, data exposure or loss of integrity. **Medium**: weakens a control or exposes data under specific conditions. **Low**: limited impact or defence in depth. **Info**: could not be assessed.

2.4 Verification states

State	Meaning
Executed	A test or scan was run in this review and its result recorded
Written, not run	An automated test exists in the repository but has not been executed anywhere by the reviewer
Reviewed only	Checked by reading the code; no automated test

3. Test and check results

3.1 Executed

Check	Result	Evidence
Syntax of every JavaScript and JSX file (TypeScript parser)	**Pass: 89 files, 39 of them JSX, 0 errors**	Run during the review
Unit test suite	**Pass: 51 of 51 (0 failed, 0 skipped), Node v22.22.2**	docs/evidence/unit-test-results.json

Check	Result	Evidence
Static scan, original code	17 high, 17 medium, 3 low	docs/evidence/static-analysis-baseline.json
Static scan, after remediation	0 high, 0 medium, 3 low (accepted token-storage finding F-19)	docs/evidence/static-analysis-after.json
Route inventory	31 routes: 6 public, 1 with optional sign-in, 24 requiring sign-in	docs/evidence/route-inventory.json

3.2 Unit suite contents

File	Tests	What it covers
config.test.js	5 of 5 passed	Startup configuration checks
middleware.test.js	12 of 12 passed	Real authentication, security and error-handling middleware with stubbed dependencies
policy.test.js	20 of 20 passed	Authorization policy: tenant and syndicate scoping, field allow-lists, read projections, verification views
validate.test.js	9 of 9 passed	Validation helpers, password policy, operator-key detection, badge normalisation
verdict.test.js	5 of 5 passed	Verification verdicts, name masking, limited view, and the mobile offline verdict executed from its real source

Three of the unit files execute real application code: the authorization policy, the validators and verdict logic, and the authentication, operator-rejection, rate-limit configuration and error-handling middleware (with the database, token library and rate limiter replaced by stubs). A further test extracts the mobile app's offline verdict function from its source and checks it against the server's for every combination of status and licence date.

3.3 Written but not executed

Integration file	Cases	Covers
rbac.test.js	74	Every protected route against all five roles (allowed or 403), unauthenticated access (401) and public endpoints
isolation.test.js	17	Cross-municipality and cross-syndicate reads and writes; id guessing; mass assignment; approval gating; reference validation; data minimisation; operator injection
badges.test.js	12	QR generation, badge format and immutability, anonymous/officer/cross-municipality verification, verdicts, revocation, incidents, offline sync and snapshot
auth.test.js	12	Sign-in, lockout, registration, password reset, token handling, CORS, headers and body limits
audit.test.js	7	Audit entries for each action, visibility by role, append-only enforcement, absence of secrets

Total: 122 cases. They run against an isolated in-memory MongoDB (or a database whose name contains "test"; the harness refuses any other). The author could not run them, so a first run may reveal test-setup errors as well as defects; treat any failure as a prompt to investigate, not as proof of either.

3.4 Static scan triage

The baseline scan was produced before the scanner's rules were refined. Of 5 baseline hits for unscoped lookups by id (SA-02), 3 were false positives: lookups by the signed-in user's own municipality, or of the top-level municipality record, which is access-controlled by role. The remaining hits were genuine and are covered by findings F-03 and F-04. The count of baseline findings by rule is in Appendix A.

4. Findings summary

ID	Severity	Title	Component	Status
F-01	High	Working demonstration credentials published in client source and seeded into the shared database	Web, mobile, seed, README	**Remediated in code**
F-02	High	Verification endpoint wrote to the database and exposed full rider details without authentication	API: /enforcement/verify	**Remediated**
F-03	High	Mass assignment on create and edit routes	API: riders, bikes, syndicates, tenants	**Remediated**
F-04	High	Cross-municipality and cross-syndicate references and writes	API: bikes, incidents, offline sync	**Remediated**
F-05	High	Secrets file and shared credentials	Delivery archives, development process	**Partially remediated; operational action open**
F-06	Medium	Syndicate record filter overrode the requested record	API: syndicates	**Remediated**
F-07	Medium	Weak brute-force and abuse protection	API: authentication, registration, reset	**Remediated**
F-08	Medium	Account enumeration through timing and responses	API: authentication	**Remediated**
F-09	Medium	Session and password-reset weaknesses	API: authentication	**Remediated**
F-10	Medium	Operator injection and type confusion in query strings and bodies	API: all routes	**Remediated**
F-11	Medium	Excessive exposure of personal data	API: riders, bikes	**Remediated**
F-12	Medium	Incomplete and mutable audit trail	API: audit	**Remediated**
F-13	Medium	Permissive server defaults and information leakage	API: configuration	**Remediated**
F-14	Medium	Destructive seed script with a default administrator password	Seed script	**Remediated (reviewed only)**
F-15	Medium	Offline synchronisation endpoint unbounded and non-idempotent	API: sync-scans; mobile	**Remediated**
F-16	Medium	Offline mode defeated by cold-start sign-out; stale-cache and device-data issues	Mobile	**Remediated (reviewed only)**
F-17	Low	Unsupported statistics on the public landing page	Web	**Remediated**
F-18	Medium	Static QR badges can be copied	Design	**Open (residual risk)**
F-19	Low	Session tokens held in unencrypted client storage	Web, mobile	**Open (recommendation)**
F-20	Medium	Offline snapshot stored unencrypted on officers' phones	Mobile	**Open (partially mitigated)**

ID	Severity	Title	Component	Status
F-21	Medium	No user provisioning, deactivation, password change or multi-factor authentication	API, web	**Open (recommendation)**
F-22	Medium	Operational posture: demonstration database, no backups, monitoring or CI	Deployment	**Open (operational)**
F-23	Info	Dependency vulnerabilities not assessed	All packages	**Open (not assessed)**
F-24	Medium	Business-rule gaps affecting verdicts	Requirements	**Open (decision required)**

5. Detailed findings

F-01 Working demonstration credentials published in client source and seeded into the shared database

Field	Detail
Severity / status	High **Remediated in code**
Component	Web, mobile, seed, README
Description	The login page listed live mayor, syndicate and officer credentials; the mobile login showed an officer hint; the same accounts are created by the seed script in the database used by the deployed service. Anyone could sign in as the mayor of the demonstration municipality.
Evidence	Static scan baseline: 5 occurrences of the demo passwords in client source (rule SA-06).
Remediation	Credentials removed from all client source; the web page shows demo logins only if supplied at build time (VITE_DEMO_ACCOUNTS, empty by default); the mobile hint was removed; the seed script requires --confirm-wipe and prints its target database.
Verification	Static scan (executed): 0 occurrences after the change.
Residual risk	The demonstration accounts still exist in any database that was seeded. Delete them or recreate the database before a pilot (gate G4).

F-02 Verification endpoint wrote to the database and exposed full rider details without authentication

Field	Detail
Severity / status	High **Remediated**
Component	API: /enforcement/verify
Description	The endpoint was public. Any holder of a badge id could read the rider's name, photo URL, syndicate, plate and licence expiry, and each call incremented the rider's verification count and created a log entry, allowing counters and logs to be inflated.
Evidence	Static scan baseline: rule SA-12 (GET handler that writes, without authentication); code reading.
Remediation	Optional authentication: anonymous callers and officers from other municipalities get a limited view (verdict and masked name) and nothing is written; a supplied but invalid token is rejected; badge ids are validated; anonymous callers are rate limited; counters use atomic updates.
Verification	Unit tests executed (view rules, limiter settings, optional-auth behaviour). Integration tests written, not run.
Residual risk	Static QR codes can still be copied (F-18).

F-03 Mass assignment on create and edit routes

Field	Detail
Severity / status	High **Remediated**
Component	API: riders, bikes, syndicates, tenants
Description	Routes passed the request body straight to the database. A syndicate administrator could create riders already active, choose their own badge id, set counters, or move records to another syndicate or municipality; council edits could change a record's municipality; a municipality's mayor could change plan, status and code.
Evidence	Static scan baseline: 5 occurrences of the request body spread into a write (rule SA-01); code reading.
Remediation	Role-specific field allow-lists decide what may be written; rider status changes only through the audited status route; the badge id is generated by the server and immutable in the model; tenant and syndicate cannot be edited after creation.
Verification	Unit tests executed (allow-lists for every role and resource). Integration tests written, not run.
Residual risk	None identified.

F-04 Cross-municipality and cross-syndicate references and writes

Field	Detail
Severity / status	High **Remediated**
Component	API: bikes, incidents, offline sync
Description	Creating a bike with a rider id modified that rider even if the rider belonged to another syndicate or municipality; incident reporting found riders by id without municipality scope; offline sync accepted any rider's badge id.
Evidence	Static scan baseline: unscoped lookups by id (SA-02) and unbounded sync input (SA-11); code reading.
Remediation	Rider references are validated against the bike's municipality and syndicate; incident and sync lookups use the caller's municipality scope; a new rider or bike's municipality is taken from its syndicate, never from the request.
Verification	Unit tests executed (scope filters). Integration tests written, not run.
Residual risk	None identified.

F-05 Secrets file and shared credentials

Field	Detail
Severity / status	High **Partially remediated; operational action open**
Component	Delivery archives, development process
Description	A local backend/.env file containing real credentials was included in project archives delivered during development, and credentials were shared in clear text in conversations. Anyone holding those archives or logs holds working credentials.
Evidence	Static scan baseline: rule SA-14 (secrets file in the project tree).
Remediation	Archives now exclude .env; .env.example documents variables without values; startup refuses a missing or weak signing secret.
Verification	Unit tests executed (startup configuration checks); static scan (executed).
Residual risk	Credentials already exposed must be rotated and earlier archives destroyed (gate G5). This cannot be done from the code.

F-06 Syndicate record filter overrode the requested record

Field	Detail
Severity / status	Medium **Remediated**
Component	API: syndicates
Description	For a syndicate administrator the scope filter replaced the identifier in the URL, so a request aimed at another syndicate's record acted on their own record instead.
Evidence	Code reading of the scope helper and routes.
Remediation	A dedicated record filter returns a no-match filter for any identifier other than the administrator's own syndicate.
Verification	Unit tests executed (record filter). Integration test written, not run.
Residual risk	None identified.

F-07 Weak brute-force and abuse protection

Field	Detail
Severity / status	Medium **Remediated**
Component	API: authentication, registration, reset
Description	One generic limit covered all authentication routes; there was no account lockout; and because the service sits behind a proxy without proxy trust configured, limits keyed on the proxy rather than the client.
Evidence	Static scan baseline: rule SA-13; code reading.
Remediation	Proxy trust configured; separate limits for sign-in, reset, registration and verification; five failed sign-ins lock an account for 15 minutes; lockouts are audited.
Verification	Unit tests executed (limiter settings). Lockout behaviour: integration test written, not run. Actual throttling is not covered by any test (limiters are disabled in the test environment).
Residual risk	Attackers distributed across many addresses can still guess passwords slowly; multi-factor authentication would address this (F-21).

F-08 Account enumeration through timing and responses

Field	Detail
Severity / status	Medium **Remediated**
Component	API: authentication
Description	Sign-in did less work for unknown accounts, and the reset request waited for an email only when the account existed, so response time revealed which emails are registered.
Evidence	Code reading.
Remediation	A dummy password comparison equalises sign-in timing; failure messages are identical for unknown, wrong and locked; reset email is sent without delaying the response.
Verification	Integration test (generic responses) written, not run. Timing was not measured.
Residual risk	Registration still reports that an email is already in use (needed for usability); it is rate limited.

F-09 Session and password-reset weaknesses

Field	Detail
Severity / status	Medium **Remediated**
Component	API: authentication
Description	Sessions remained valid after a password reset; in production, when email was not configured, the reset link was printed to the server log; registration had no password rules; tokens were verified without pinning the algorithm.
Evidence	Code reading.
Remediation	Tokens issued before the last password change are rejected; reset links are never logged in production; a password policy applies to registration and reset; verification pins HS256.
Verification	Unit tests executed (session-age rule, algorithm pinning). Reset flow: integration test written, not run.
Residual risk	No server-side revocation list and no refresh tokens (section 6).

F-10 Operator injection and type confusion in query strings and bodies

Field	Detail
Severity / status	Medium **Remediated**
Component	API: all routes
Description	Nested query-string objects reached database filters, and object values in sign-in or reset fields caused server errors, so request shape could change query behaviour.
Evidence	Static scan baseline: 10 occurrences of query values placed in filters (rule SA-03).
Remediation	Query strings are parsed without nesting; filters accept strings only from allow-lists; bodies, queries and parameters containing keys that start with $, contain a dot, or are prototype names are rejected; credential fields must be strings.
Verification	Unit tests executed (operator rejection middleware executed against crafted payloads; validators). Integration tests written, not run.
Residual risk	None identified.

F-11 Excessive exposure of personal data

Field	Detail
Severity / status	Medium **Remediated**
Component	API: riders, bikes
Description	National ID number and date of birth were returned in every rider query to every role; officers received all riders' phone numbers and could generate badge QR codes.
Evidence	Code reading.
Remediation	Identity numbers are excluded by default and returned only in the single-rider detail view to non-officer roles; officers never receive phone numbers; badge generation is restricted to managers.
Verification	Unit tests executed (projections). Integration tests written, not run.
Residual risk	Officers can still list their municipality's riders and syndicates (SRS, section 3).

F-12 Incomplete and mutable audit trail

Field	Detail
Severity / status	Medium **Remediated**
Component	API: audit
Description	Only three kinds of action were audited; generic edits could change a rider's status without an entry; actions by the platform administrator could not be recorded because a municipality was mandatory; entries could be modified or deleted through the application.
Evidence	Code reading.
Remediation	Sixteen administrative actions are audited with actor, role, before and after values and IP; status changes only through audited routes; platform-administrator actions are recordable; update and delete operations on the audit model are blocked.
Verification	Integration tests written, not run (including append-only checks).
Residual risk	Someone with database credentials can still alter the log; use a restricted database role and external log storage. A failed audit write does not block the action (design decision).

F-13 Permissive server defaults and information leakage

Field	Detail
Severity / status	Medium **Remediated**
Component	API: configuration
Description	A wildcard CORS origin was accepted, the JSON body limit was 5 MB on an API with no uploads, error details were returned outside production, and the service started with a missing or weak signing secret.
Evidence	Static scan baseline: rules SA-07 and SA-09.
Remediation	No wildcard origins; 100 KB limit; production errors are generic; startup refuses missing or weak secrets; headers hardened.
Verification	Unit tests executed (error handler, configuration checks). CORS and headers: integration test written, not run.
Residual risk	None identified.

F-14 Destructive seed script with a default administrator password

Field	Detail
Severity / status	Medium **Remediated (reviewed only)**
Component	Seed script
Description	The script deleted every collection in whichever database it was pointed at without confirmation and fell back to a published administrator password.
Evidence	Code reading.
Remediation	Requires --confirm-wipe, prints the target host and database, generates a random administrator password when none is supplied, and clears the audit collection through the raw driver.
Verification	Syntax checked; not executed against a database.
Residual risk	The demonstration accounts it creates use documented passwords by design.

F-15 Offline synchronisation endpoint unbounded and non-idempotent

Field	Detail
Severity / status	Medium **Remediated**
Component	API: sync-scans; mobile
Description	The endpoint accepted unlimited batches, any municipality's riders, arbitrary verdict text and timestamps, and re-sent batches created duplicates.
Evidence	Static scan baseline: rule SA-11.
Remediation	At most 200 scans per request; verdicts and badge ids validated; own-municipality riders only; scans older than 30 days rejected and future timestamps clamped; per-officer unique scan ids make retries safe; entries are marked as offline-synced.
Verification	Integration tests written, not run.
Residual risk	The verdict recorded for an offline scan is what the device displayed (client-asserted).

F-16 Offline mode defeated by cold-start sign-out; stale-cache and device-data issues

Field	Detail
Severity / status	Medium **Remediated (reviewed only)**
Component	Mobile
Description	If the app was opened without network, the failed profile request removed the saved session and signed the officer out, so offline scanning could not be used after a restart. Requests had no timeout; any error, including authentication failures, was answered from the cache; cached rider data was not removed on sign-out.
Evidence	Code reading of the mobile authentication and result flows.
Remediation	Only an explicit 401 ends a session; otherwise the last profile is kept; 12-second timeout; the cache is used only for connectivity failures (no response, 502-504); sign-out removes the snapshot, queue and recent scans; scans carry unique ids.
Verification	Unit tests executed: the mobile verdict function was executed and matches the server. Everything else: reviewed only; no automated mobile tests exist.
Residual risk	Verify on a physical device with airplane mode before relying on it.

F-17 Unsupported statistics on the public landing page

Field	Detail
Severity / status	Low **Remediated**
Component	Web
Description	The page claimed 99.9% availability, 10,000+ verifiable riders and 15+ councils, none of which is supported by evidence, and a sample panel presented illustrative data as live.
Evidence	Static scan baseline: 3 occurrences (rule SA-10).
Remediation	Replaced with factual capability statements; the sample panel is labelled as sample data.
Verification	Static scan (executed): 0 occurrences.
Residual risk	None.

F-18 Static QR badges can be copied

Field	Detail
Severity / status	Medium **Open (residual risk)**
Component	Design
Description	The QR code contains only the badge id. A photograph of a badge can be shown by another person.
Evidence	Design review.
Remediation	Mitigations only: officers see name, syndicate and plate for comparison; revocation takes effect at the next scan.
Verification	Not applicable.
Residual risk	Consider rotating or signed codes and in-app photo comparison for a later phase.

F-19 Session tokens held in unencrypted client storage

Field	Detail
Severity / status	Low **Open (recommendation)**
Component	Web, mobile
Description	The web app keeps the token in localStorage, readable by any script running on the page; the mobile app keeps it in application storage that is not hardware-backed.
Evidence	Static scan: 3 occurrences (rule SA-08).
Remediation	Not changed. Recommended: httpOnly cookie with CSRF protection for the web, secure storage for mobile, and shorter lifetimes.
Verification	Not applicable.
Residual risk	The web app loads no third-party scripts apart from fonts, and React escapes output, which limits exposure.

F-20 Offline snapshot stored unencrypted on officers' phones

Field	Detail
Severity / status	Medium **Open (partially mitigated)**
Component	Mobile
Description	Names, statuses, licence dates, syndicates and plates for a municipality are stored in application storage.
Evidence	Code reading.
Remediation	Snapshot contains no phone numbers or identity numbers and is removed on sign-out.
Verification	Reviewed only.
Residual risk	Lost, unlocked phones expose the snapshot; deactivating the account does not erase it. Add storage encryption.

F-21 No user provisioning, deactivation, password change or multi-factor authentication

Field	Detail
Severity / status	Medium **Open (recommendation)**
Component	API, web
Description	Staff and officer accounts can only be created by operator tooling; there is no screen to deactivate a user or for users to change their password; privileged roles rely on a password alone.
Evidence	Route inventory (31 routes): none provides these functions.
Remediation	Not implemented; documented as the main operational prerequisite.
Verification	Not applicable.
Residual risk	Required for a managed pilot.

F-22 Operational posture: demonstration database, no backups, monitoring or CI

Field	Detail
Severity / status	Medium **Open (operational)**
Component	Deployment
Description	A single database is used for demonstration; the reported hosting tiers sleep when idle and have no availability commitment; the repository contains no CI workflow, backup, monitoring or infrastructure definition.
Evidence	Repository inspection; deployment details as reported by the owner.
Remediation	Not changed (outside the code). See the Governance Policy, sections 7, 8 and 10.
Verification	Not applicable.
Residual risk	Needed before any reliance by enforcement staff.

F-23 Dependency vulnerabilities not assessed

Field	Detail
Severity / status	Info **Open (not assessed)**
Component	All packages
Description	The advisory database could not be queried because the review environment had no network access. The owner reported that installing the backend reported 1 moderate-severity advisory and the mobile package reported 16 moderate-severity advisories; details were not available.
Evidence	Owner-reported terminal output (unverified). Static scan: no unused runtime dependency remained in the backend after removing the uuid package.
Remediation	Run npm audit --omit=dev in backend, web and mobile and attach the results.
Verification	Not run.
Residual risk	Unknown until the audit is run.

F-24 Business-rule gaps affecting verdicts

Field	Detail
Severity / status	Medium **Open (decision required)**
Component	Requirements
Description	Suspending a syndicate does not change its riders' verdicts; insurance and roadworthiness do not affect the verdict; officers from other municipalities see a limited view. Whether these match the institution's intent is undecided.
Evidence	Code and requirements review (SRS, BR-10 to BR-12).
Remediation	Decisions required from the municipality; implementation is small once decided.
Verification	Not applicable.
Residual risk	A syndicate suspended for cause could still produce valid badges.

6. Remaining risks and recommendations

6.1 Before a pilot

1. Run the integration suite on a clean install and fix any failures (gate G2).
2. Run npm audit in backend, web and mobile and resolve high or critical advisories (G3).
3. Rotate every credential shared during development; delete demonstration accounts; use separate databases per environment (G4, G5).
4. Provide a way to create and deactivate staff and officer accounts and let users change their password (F-21).
5. Configure backups with a tested restore, and choose a hosting tier with a defined availability (F-22).
6. Obtain the municipality's decisions on F-24 and legal validation of the Governance Policy, section 14.
7. Commission an independent penetration test of the deployed system (G10).

6.2 Within the first months of a pilot

- Multi-factor authentication for council and platform-administrator roles.
- Secure token storage and shorter lifetimes with refresh tokens; encrypted offline snapshot.
- Restricted database role and external storage for audit entries; central logging and alerting.
- Rider and bike enrolment screens; photo capture; pagination and search.

6.3 Longer term

- Rotating or signed QR badges and in-app photo comparison.
- Automated CI running tests, static checks and dependency audit on every change.
- Retention and data-subject tooling matching the confirmed legal requirements.

7. Reproducing and extending this assessment

Commands, run from the project root:

Purpose	Command	Notes
Install backend dependencies	cd backend && npm install	Needed once; includes supertest and mongodb-memory-server
Unit tests	npm run test:unit	No database required
Integration tests	npm run test:integration	Downloads a MongoDB binary on first use; or set TEST_MONGO_URI to a database whose name contains "test"
All tests	npm test	Writes backend/tests/last-results.json
Static checks and route inventory	npm run check:static	Exit code 1 if any high finding
Dependency advisories	npm run audit:deps (also in web and mobile)	Attach output as evidence for gate G3

Attach the outputs of these commands, dated, to this report when it is submitted for review so that every statement of fact can be traced to a result.

Appendix A. Static scan rule catalogue and baseline counts

Rule	Severity	Weakness	Baseline hits	After

The scanner is intentionally narrow: it detects the specific patterns found in this review so they cannot silently return. A clean scan is not evidence that no vulnerability exists.